

to be scanned. The script then includes an element in the Web page (such as an image, *IFRAME* or remote script) that is addressed by the URL. Also, using JavaScript time-out functions, and event handlers like *OnLoad* and *OnError*, the script can decide whether the host exists and whether the given port is open. If a time-out occurs, the host probably does not exist. An *OnLoad* event indicates that the host probably runs a Web server, and an *OnError* event indicates that the host exists, but the port is closed. The typical attack scenario is shown in Figure 6. In this scenario, the attacker forces/convince the intranet user to visit a malicious page on the attacker's server, which contains the following HTML in a hidden *IFRAME*:

```
<SCRIPT SRC="http://211.224.196.1/"></SCRIPT>
```

As soon as the user executes this page, the information about the existence of the Web server is sent to the attacker in the form of errors. Apart from this, the attacker can fingerprint applications/routers/network devices, and also might locate HTTPS or development servers by varying the ports.

Same Origin Policy

Web browsers use a security model called the same-origin policy (SOP) to enforce some access restrictions on Web applications. The SOP identifies each website using its origin, which is a unique combination of protocol, domain and port, and creates a context for each origin. Two resources are considered to be of the same origin only if all these values are exactly the same.

Guarding against CSRF attacks

Following a few guidelines for both users and developers can help to curb CSRF attacks a lot.

For users

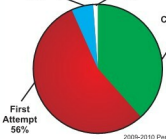
1. Log out of the important Web application when you have completed your work/transactions. Do not open any non-trusted site in

the same browser while logged in to the important site. If you need to do this for some reason, use a separate browser for the untrusted site(s).

2. Use Mozilla Firefox with the NoScript add-on, which allows JavaScript, Java and other executable content to run only from trusted domains of your choice. It is one of the best defences available for protection against XSS, CSRF and click-jacking attacks. Also consider using the CsFire add-ons, which autonomously protect you against CSRF and other dangerous or malicious cross-domain requests. CsFire will remove authentication information (cookies and authentication headers).
3. Use multiple browsers and segregate your browsing into trusted/sensitive sites/applications and untrusted/less important sites/applications. For example, use Firefox, with the NoScript and Adblock Plus (ABP) add-ons installed, to browse trusted/sensitive sites/applications. In NoScript, white-list trusted sites so JavaScript from those sites will work. Set up ABP to block known malicious sites; use the auto-configuration URL at the end of <http://adblockplus.org/blog/blocking-malicious-sites-with-adblock-plus> to add the filter list to ABP. For other (untrusted) sites, install another browser like Google Chrome, Chromium or Opera. If you're not certain about off-site links encountered in trusted sites (e.g., someone mails you a link to your Gmail, which you're viewing in Firefox), then instead of visiting it in Firefox, drag the link from the page in Firefox to Chrome/Chromium's tab bar (or copy/paste it), to have it open in a new tab in Chromium. Since only the link URL is transferred to the other browser, and any implicit-authentication tokens remain in Firefox, this is a safer practice.
4. Regularly deleting long-duration cookies (those which are set to


redhat®
TRAINING PARTNER
RHCE / RHCVA / RHCSS
Exam Centre

Second Attempt 5% Not Clear 1% Centum 38%



2009-2010 Performance

At ADVANTAGE PRO, we do not make tall claims but produce 99% results month after month – TAMIL NADU'S NO. #1 PERFORMING REDHAT PARTNER



Only @ Advantage Pro

Redhat Career Program from THE EXPERT

Also get expert training on My SQL-CMDBA, My SQL-CMDEV, PHP, Perl, Python, Ruby, Ajax...

Next RHCE/RHCSS Exam
8th & 22nd Nov. 2010

"Do Not Wait! Be a Part of the Winning Team"


ADVANTAGE PRO
 IT TRAINING DIVISION OF
 Vectra Technology Pvt. Ltd.
 Open Source Academy

Regd. Off: Wing 1 & 2, IV Floor,
Jhaver Plaza, 1A, N.H. Road,
Nungambakkam, Chennai - 34.
Ph : 28263529 / 3530 / 3540
Telefax : 28263527
E-mail : enquiry@vectratech.in
www.vectratech.in